PHOENIX SECURITY

CYBER RISK DEFENDERS CLUB

WEBINAR

REACHABILITY ANALYSIS AND THE FUTURE OF ASPM

Fireside conversation with James Berthoty

ASPM, CNAPP, Reachability analysis, why they are all connected and why is the future of application security actionable considering what you build and where you run it so important

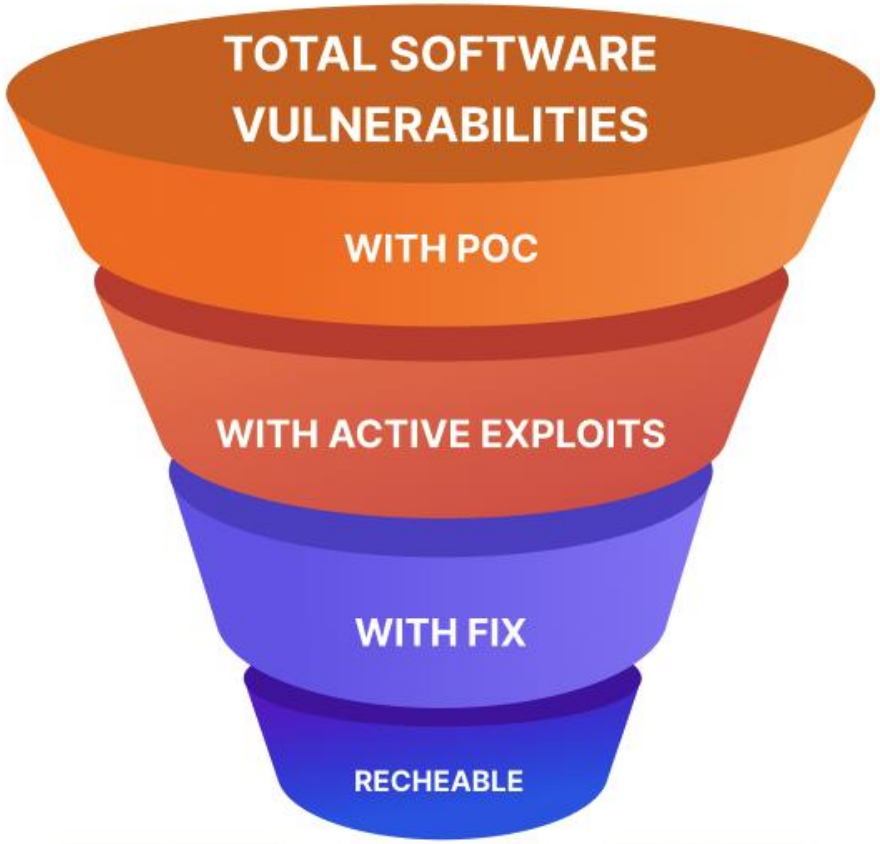
James Berthoty

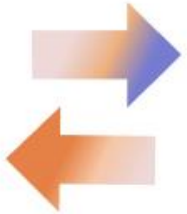
APPLICATION SECURITY EXPERT
TURNED ANALYSIS @ LATIO TECH

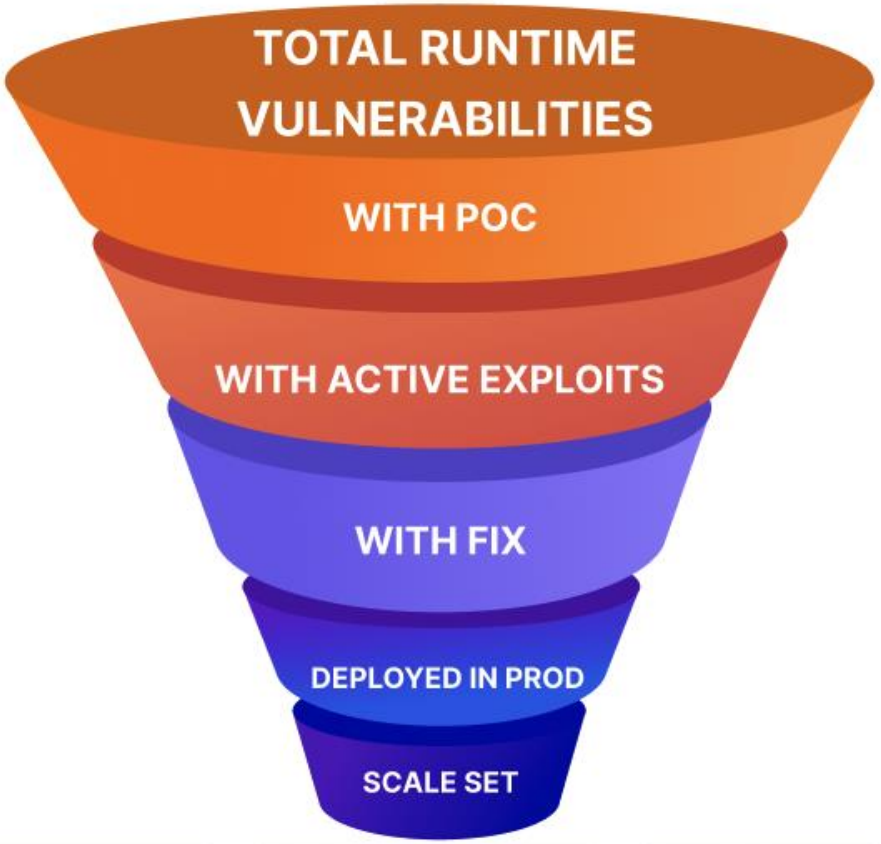
www.phoenix.security.com 30 October

10 AM PST / 12 AM CT / 1 PM ET/ 5 PM GMT

Prioritization varies depending on the deployment



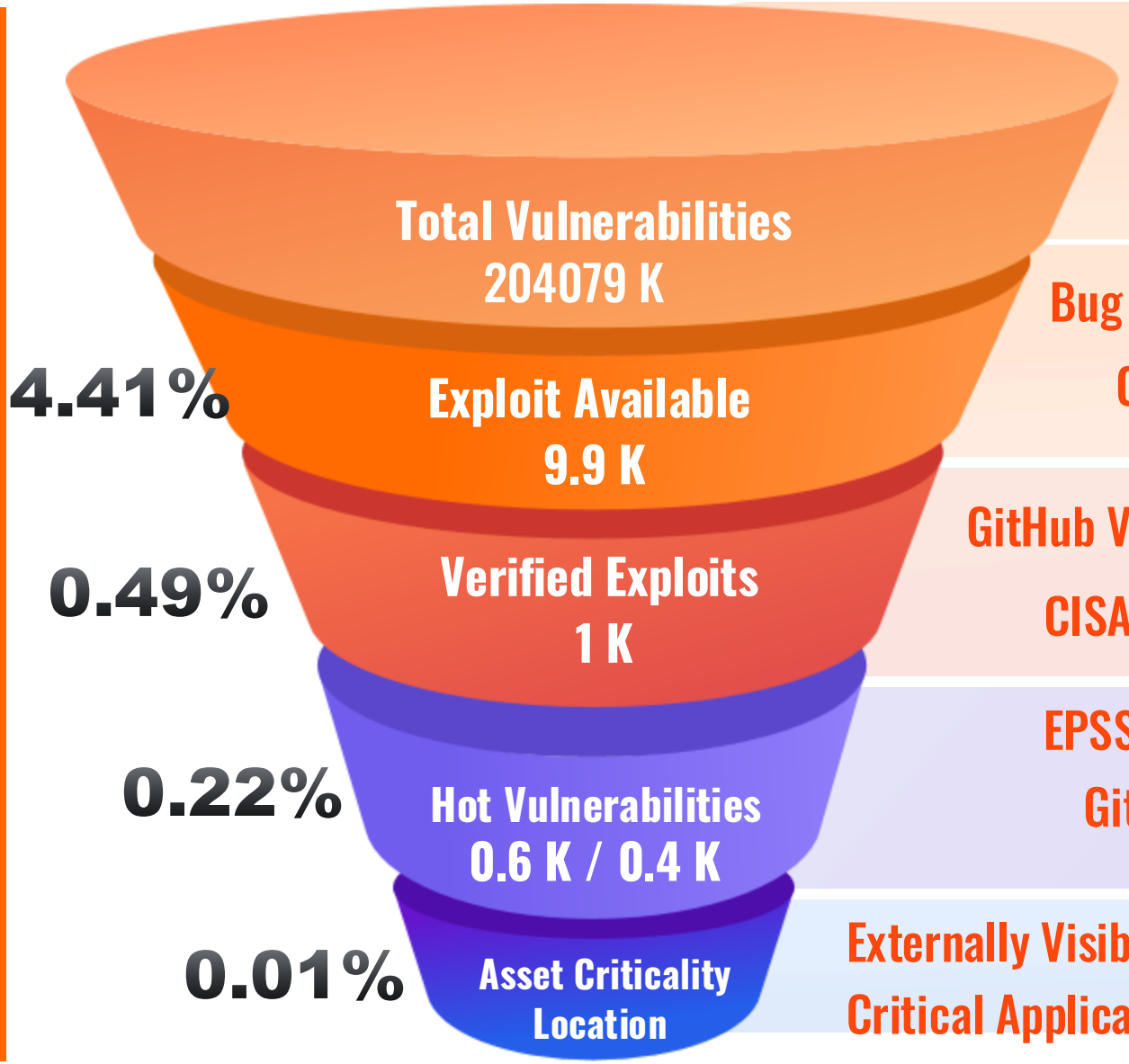




LIBRARIES | SOFTWARE | WEB/ API

CLOUD | INFRASTRUCTURE | CONTAINER

Not all the vulnerabilities require equal attention



Bug Bounty Popularity (active 17K) 8.33%

GitHub Exploit (9.9K) 4.41%

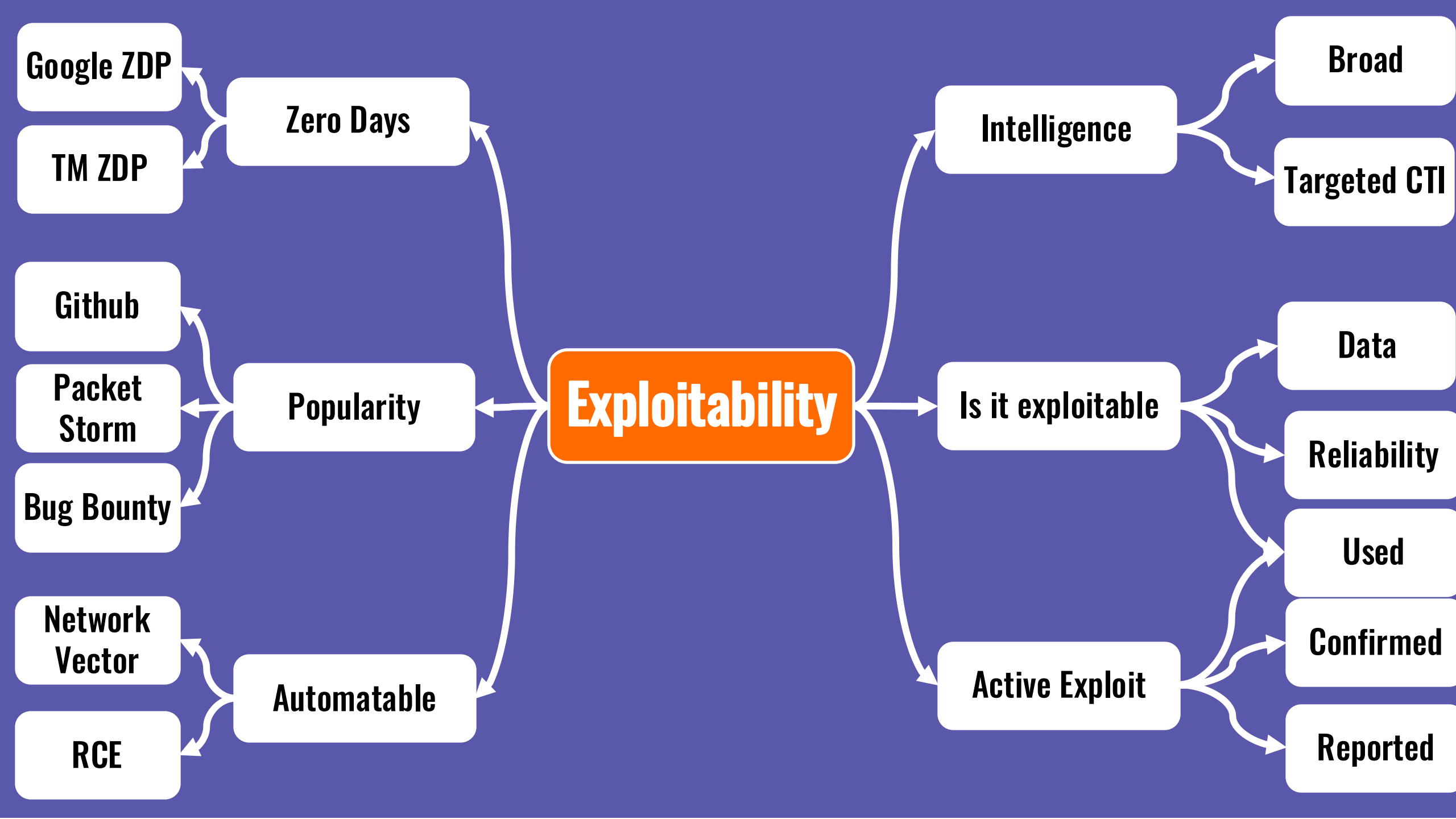
GitHub Verified Exploits (0.93K) 0.47%

CISA KEV (1K) 0.49%

EPSS > 0.7 (688) 0.34%

GitHub Active Exploit (0.40K) 0.22%

Externally Visible (0.14) ? Critical Application 0.?%

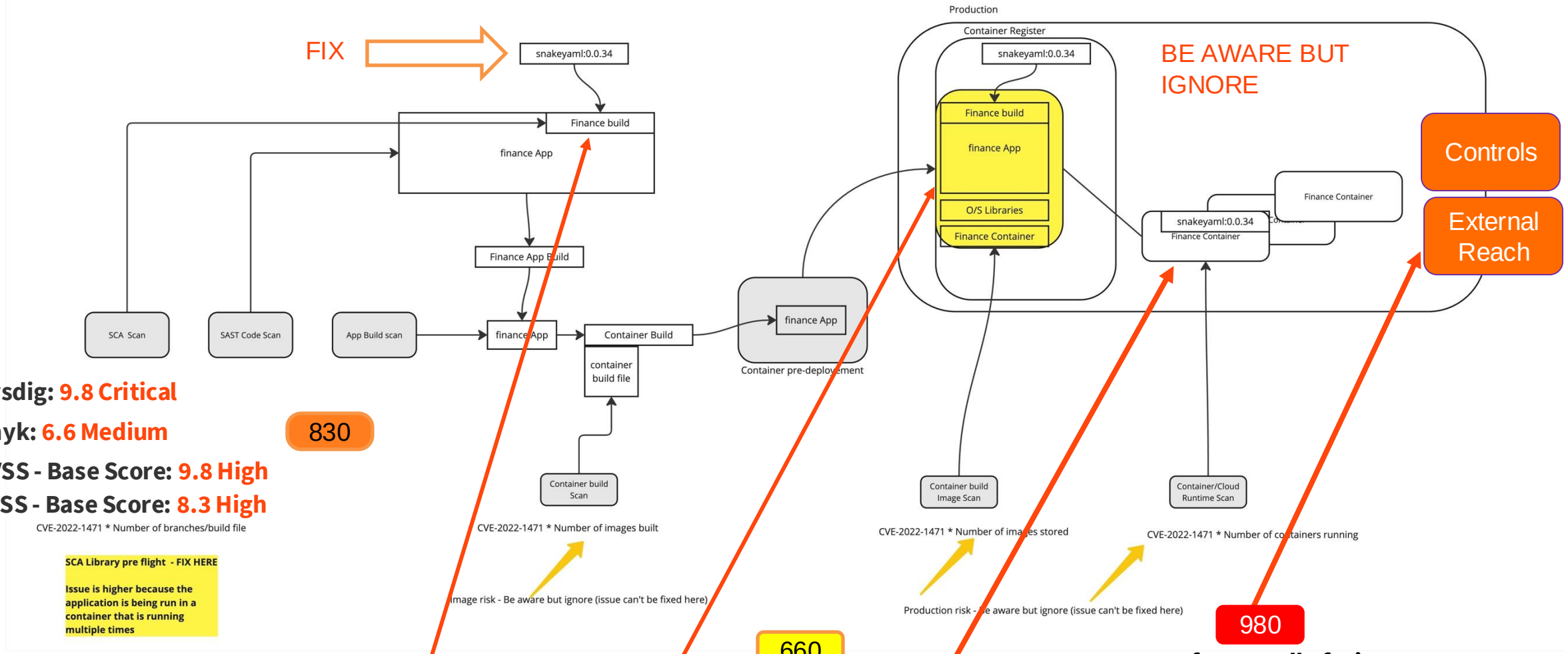

Exploitability
Zero Days
Google ZDP
TM ZDP
Popularity
Github
Packet Storm
Bug Bounty
Automatable
Network Vector
RCE
Intelligence
Broad
Targeted CTI
Is it exploitable
Data
Reliability
Active Exploit
Used
Confirmed
Reported

Reachability Analysis

Reachability Analysis of a Vulnerability

	Code Reach Reach Analysis	Runtime Reach Analysis	Container Reach Analysis	Network Reach Analysis	CTI	CTI - Exploitability
WHAT	Analyze function or library being created	Test if library is is being loaded loaded in container	Detect if the library is in a container or OS	Verify if a container's library/node is is reachable	Like EPSS identify if a vulnerability is is being exploited	Exploit evidence of a a vulnerability vulnerability
WHEN/ WERE	Code, Repo, Build	Runtime/ Build	Container Analysis, Build File	Cloud/ Operation	Everywhere	Everywhere
BENEFITS	Reduce vulnerabilities in lib/function not used	Helps identify if the code is being loaded in a container, and which container	Identify if the base image, container image or Software needs update	Helps identify if the vulnerability can be reached from Remote	Prioritization of vulnerabilities based on exploitation in wild	Prioritization of vulnerabilities based on exploit evidence
LIMITATIONS	Complex and per language	More intrusive and intensive in some instances Might require Pipeline integration	Requires container analysis	Cloud/ Network reachability analysis	Only works for network detectable Exploits	Base indicator If there is an exploit in the wild

Real Case Scenario : Deduplicating Contextually Code and Libraries



Sysdig: 9.8 Critical

Snyk: 6.6 Medium

830

CVSS - Base Score: 9.8 High

CVSS - Base Score: 8.3 High

SCA Library pre flight - FIX HERE

Issue is higher because the application is being run in a container that is running multiple times

CVSS - Base Score: 8.3 High

700

If not statically reachable -> 700

If network raceable 9 (loaded in a container)

900

660

! **EPSS - 2%** 0.021010000

Exploit available

RCE

980

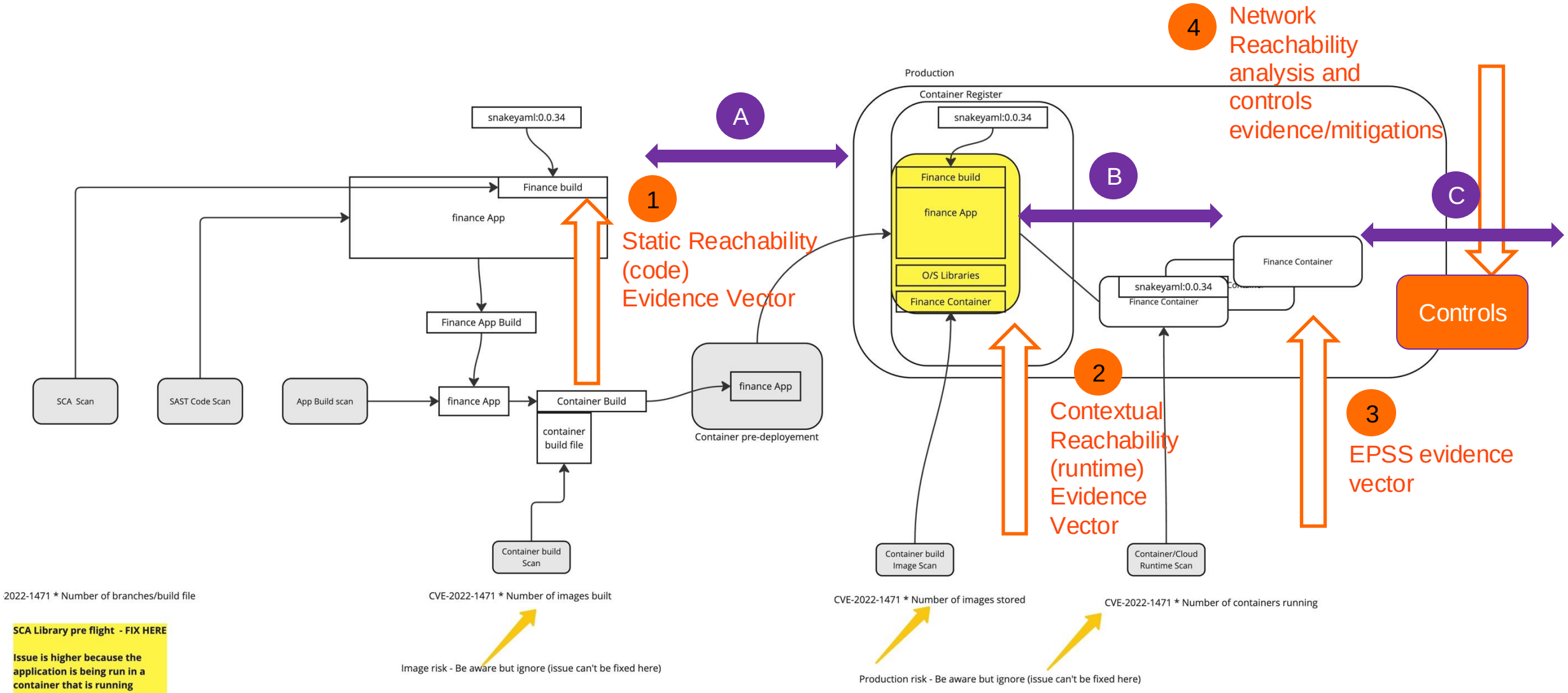
If externally facing

9.8 / 980

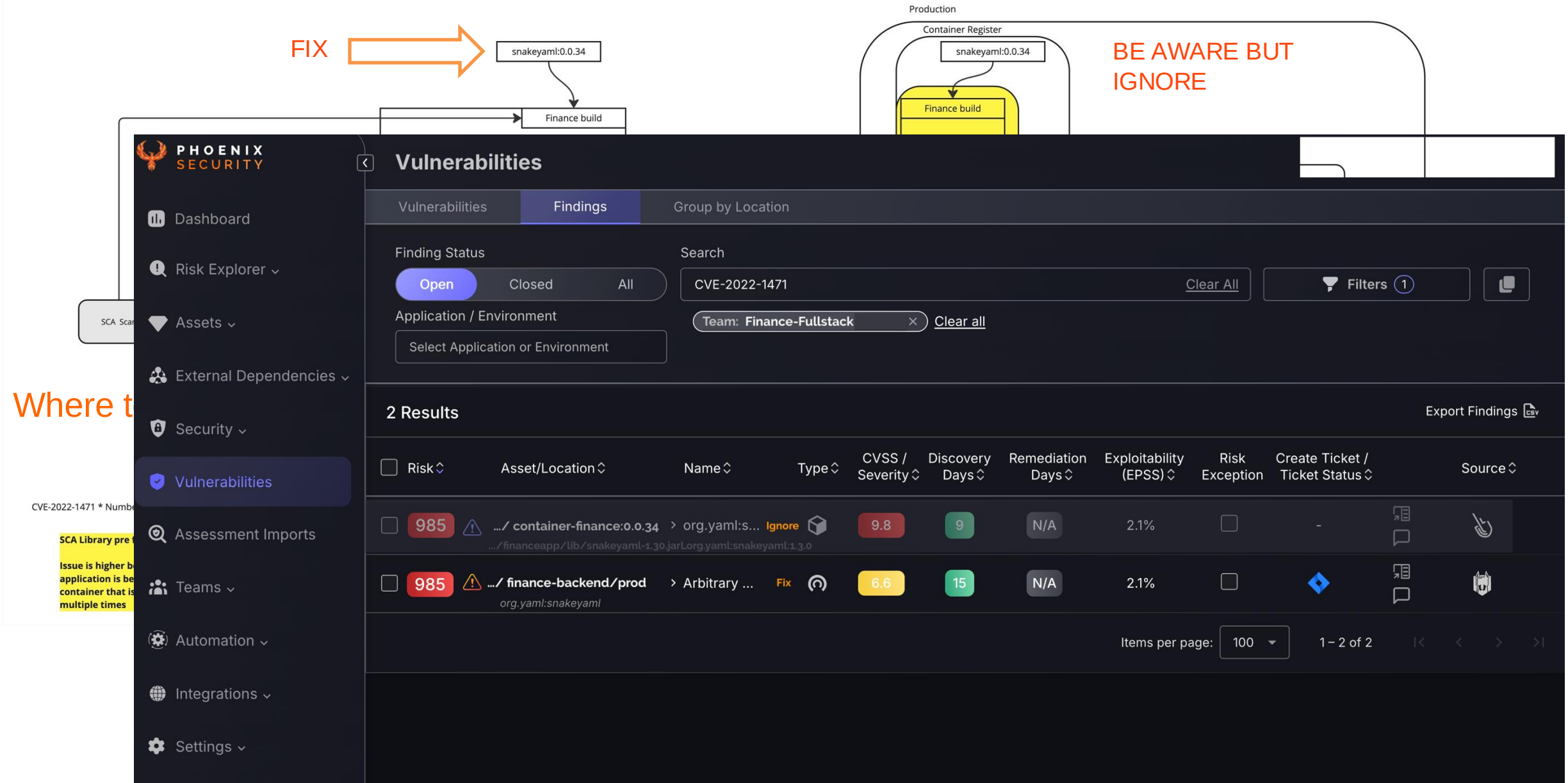
Reachability Analysis of a Vulnerability

	1 Code Reach Analysis	2 Runtime Reach Analysis	2 Container Reach Analysis	4 Network Reach Analysis	3 CTI	3 CTI - Exploitability
WHAT	Analyze function or library being created	Test if library is being loaded in container	Detect if the container is being loaded	Verify if a container's library/node is is reachable	Like EPSS identify if a vulnerability is being exploited	Exploit evidence of a vulnerability
WHEN/ / WERE	Code, Repo, Build	Runtime/ Build	Cluster analysis of container	Cloud/ Operation	Everywhere	Everywhere
BENEFITS	Reduce lib/function not used	Helps identify if the code is being loaded in in a container, and which container	Image of the container is used in runtime	Helps identify if the vulnerability can be reached from Remote	Prioritization of vulnerabilities based on exploitation in wild	Prioritization of vulnerabilities on exploit
LIMITATIONS	Complex and per language	More intrusive and intensive in some instances Might require Pipeline integration	Requires connection to container	Cloud/ Network reachability analysis	Only works for network detectable Exploits	Base indicator If there is an exploit in the wild

Real Case Scenario : EPSS vs Static Reachability vs Runtime/Contextual Reachability

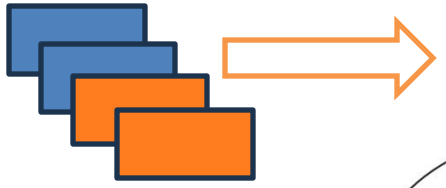


Real Case Scenario : Deduplicating Contextually Code and Libraries

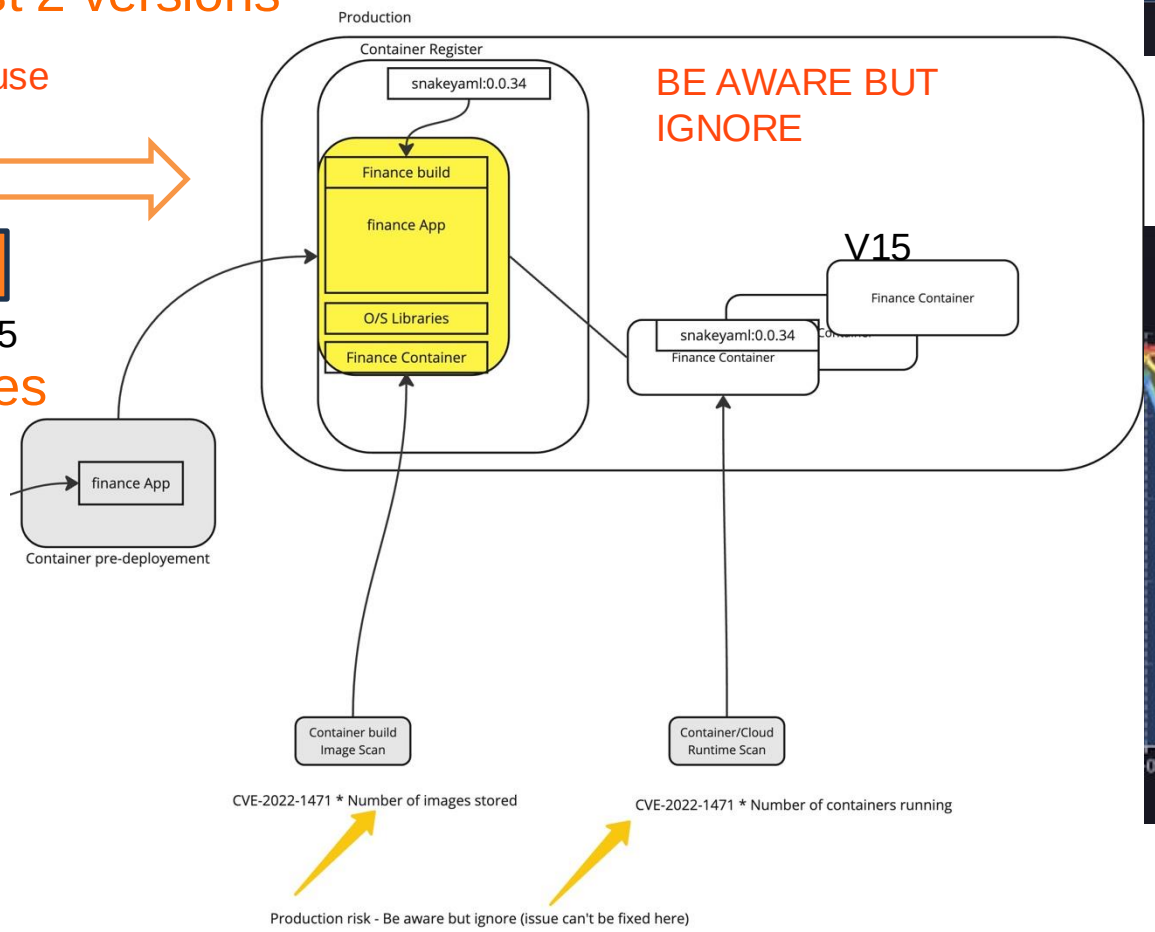


Container Version Throttling

Keep Last 2 versions

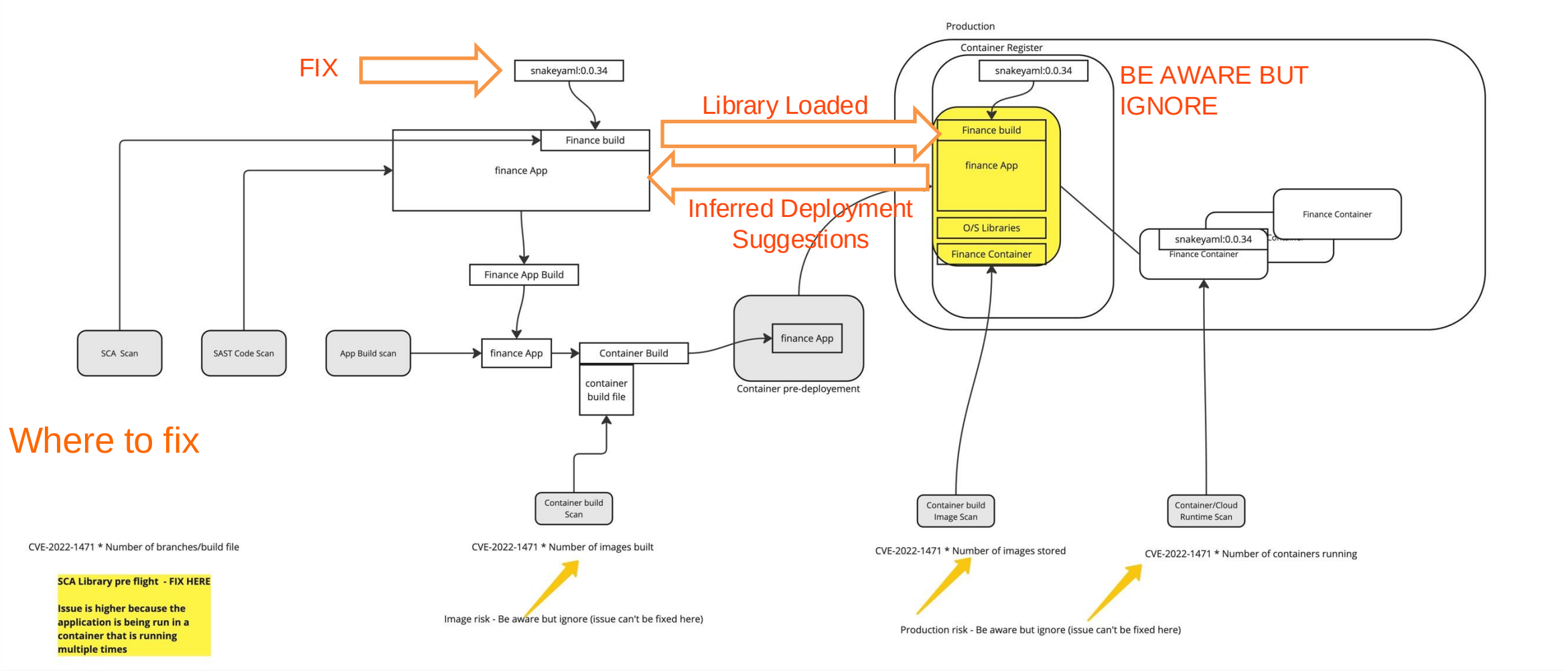


Used 15 times

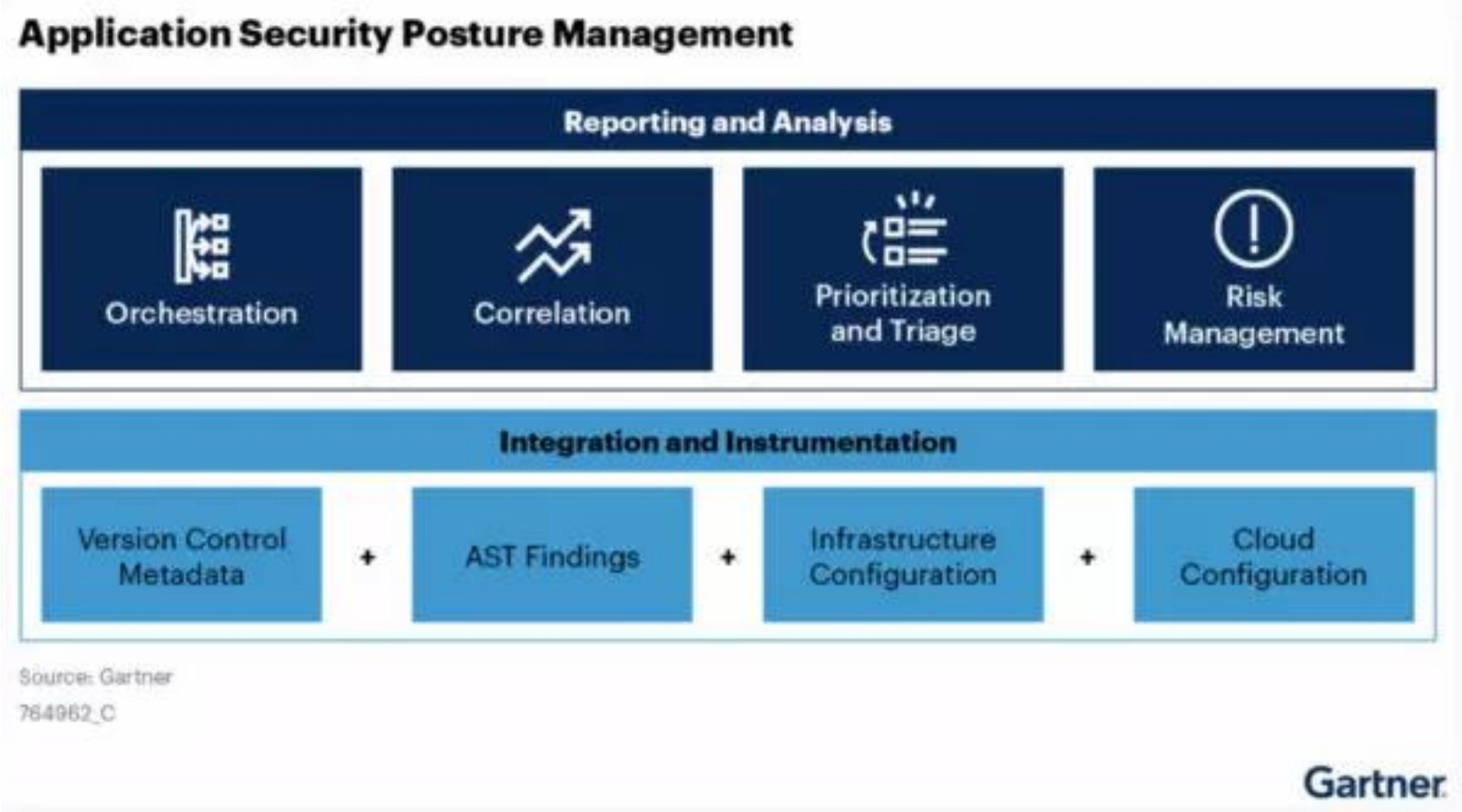


91% Reduction of Container Vulnerabilities

Real Case Scenario : Linking Application and environment



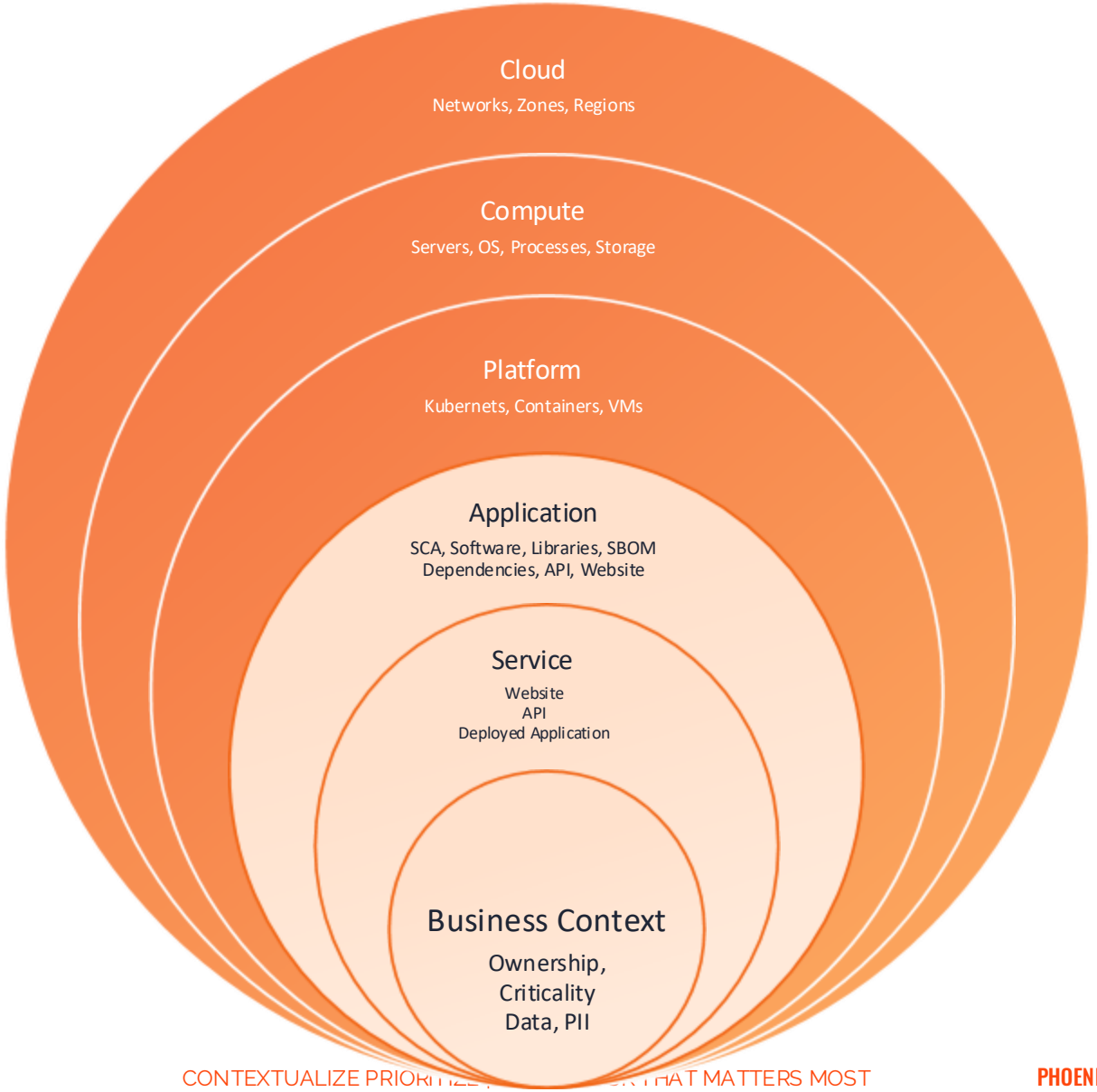
ASPM Bringing everything together


Application Security Posture Management
Reporting and Analysis
Orchestration
Correlation
Prioritization and Triage
Risk Management
Integration and Instrumentation
Version Control Metadata
+
AST Findings
+
Infrastructure Configuration
+
Cloud Configuration
Source: Gartner
764962_C
Gartner

Risk Based Cyber Surface Management

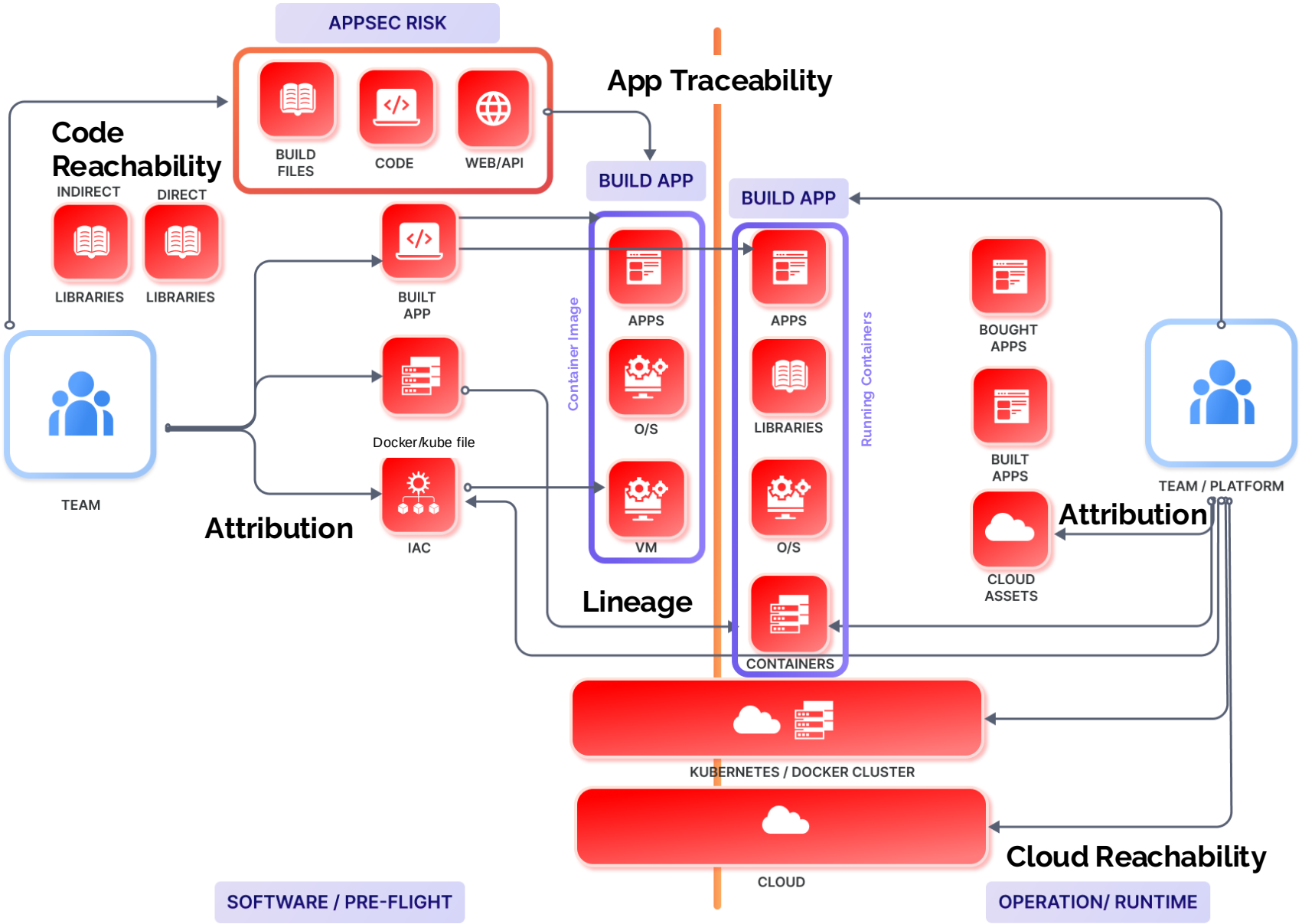
	ASPMM	SAST	SCA	DAST	IAST	CSPM
WHAT	Correlate Code Code to Cloud Cloud	Test source code	Analyse open source software libraries	Test Running application in QA	Test Running application in QA	Test Running application in QA
WHEN/ WHERE	Prodd	Dev (IDE or code repo)	Dev (Code repo)	QA	QA	QA
BENEFITS	Helps Organization understand risk	Helps developers commit and fix secure code early	Reduces open source vulnerabilities	Helps pen testers fins holes in a running application	Specifies location of vulnerabilities in code	Specifies location of vulnerabilities in code
LIMITATIONS		• False positives • Intensive to run • Blocks pipeline	• Limited scope • Custom code	Test coverage	• Agent based • Difficult to maintain	• Agent based • Difficult to maintain

Code - Application Security / ASPM + ENVIRONMENT- Rumtime

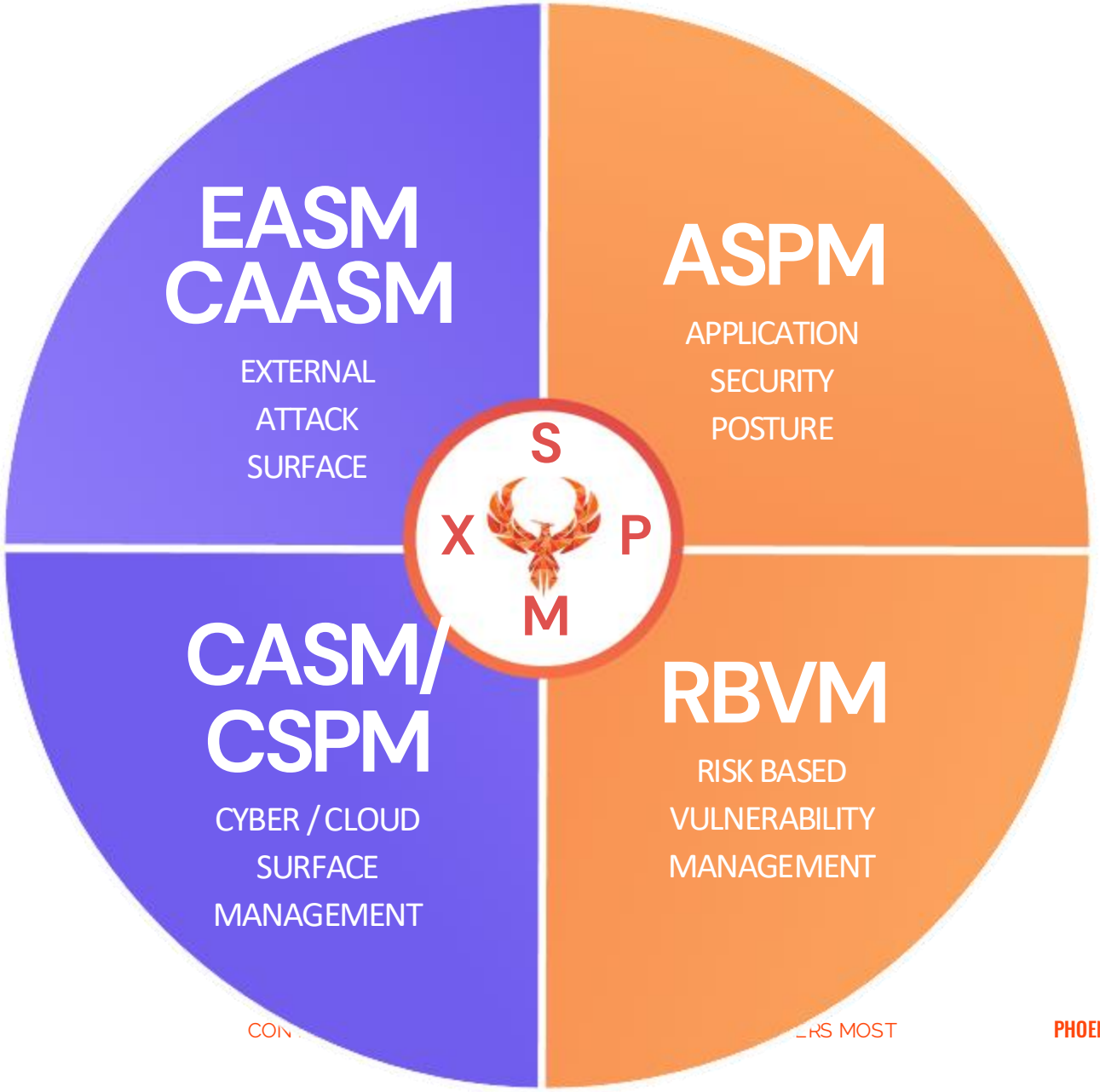


To attribute the right risk the right attribution we solve 4 problems

- Attribution
- Lineage
- Traceability
- Code/Cloud Reachability



PHOENIX SECURITY EXTERNAL, INTERNAL, SURFACE MANAGEMENT



CON ERS MOST

PHOENIX SECURITY EXTERNAL, INTERNAL, APPLICATION SURFACE MANAGEMENT

EASM CAASM

- Website
- IP
- API

ASPM

- App, API
- Libraries
- SBOM
- SAST

Business Context

Team Attribution

Runtime Tracebility

eXtended Surface Posture Management (XSPM)

(XSPM)

- ASPM
- RBVM
- Deployment traceability with canaries
- Team performance tracking
- Cross assets asset association (library from SCA and container)
- Cyber Asset Management
- Cloud Based Vulnerability Management

CASM CSPM

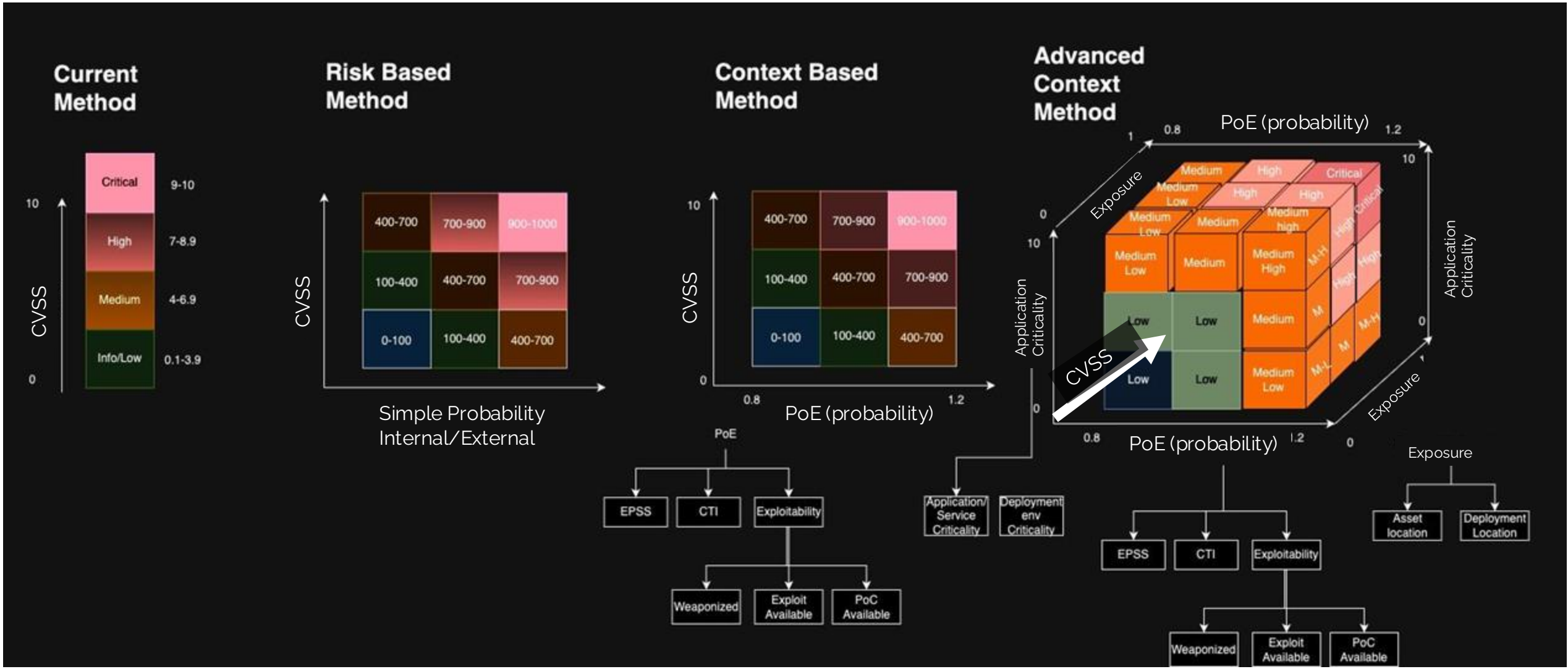
- Container
- Cloud assets
- VM

RBVM

- VM
- APPS
- O/S
- THREAT INTEL

Risk & Quantification

Phoenix brings out the 4th dimension of risk



Stages of triaging

Easy/Automatable → Harder/Manual

S1 - Bulk	S2 - Locality	S3 - Bus.	S4 – INT Reasons
Automate	Automate	Automate	Manual
Prioritize vulnerabilities	**Is it reachable?**	**Is it critical?**	**Now?**
Exploitability	Exploitability	Bus Criticality	False Positive
Active Bounty	Location		Deferred (project)
Vector	Reach (network)		Bus Reason
Reachability (code)	Attack Path	FAIR Analysis	

Easy → Harder

WHERE ARE YOU IN YOUR SOFTWARE SECURITY MATURITY JOURNEY?

PRODUCT SECURITY APPSEC MATURITY

SCAN

- Scan
- Web
- Asset
- Pentest
- Excel spreadsheet

REACT AD-HOC

- React to Vulnerabilities
- Manual Selection
- Excel spreadsheet

AGGREGATION

(aggregated view on risk)

- Aggregate
- Deduplicate
- SAST/DAST
- Pentest/Manual
- Manual Assessments
- SLAs
- Vulnerability Mngm

PRIORITIZATION ATTRIBUTION

- Severity
- Exploitability
- Fix Availability
- Criticality
- Exposure to Attack
- Risk based

CONTEXTUALIZATION

(contextual code 2 cloud)

- Application Criticality/ BIA
- Risk based
- Cyber threat
- Deployment
- Business Value & Quantification
- Criticality & Data
- Exposure
- Risk based
- Vuln Mngm

AUTOMATION

- Auto open ticket
- Auto correlate code to cloud vulnerabilities
- IaC to cloud assets
- Auto Attribute teams and users
- Workflows
- Auto Asset Management
- CI/CD feeds
- CMDB Feeds

ACT ON RISK

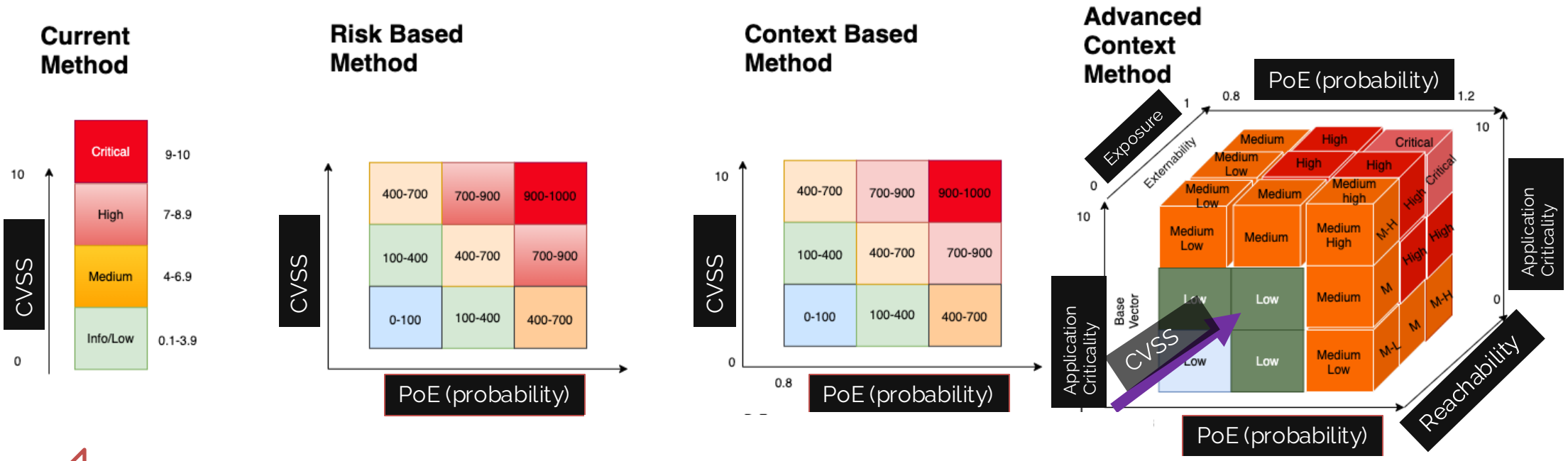
- Risk Based vulnerabilities selection
- **Attribution** of Vulnerabilities delivered to the right teams
- Vulnerability Fix Rate
- Ignore the wrong vulnerabilities
- SLA & Reaction
- MTTR/ MTO
- Per Sprint fix

MANUAL

AUTOMATE

CONTEXTUALIZE PRIORITIZE | ACT ON RISK THAT MATTERS MOST

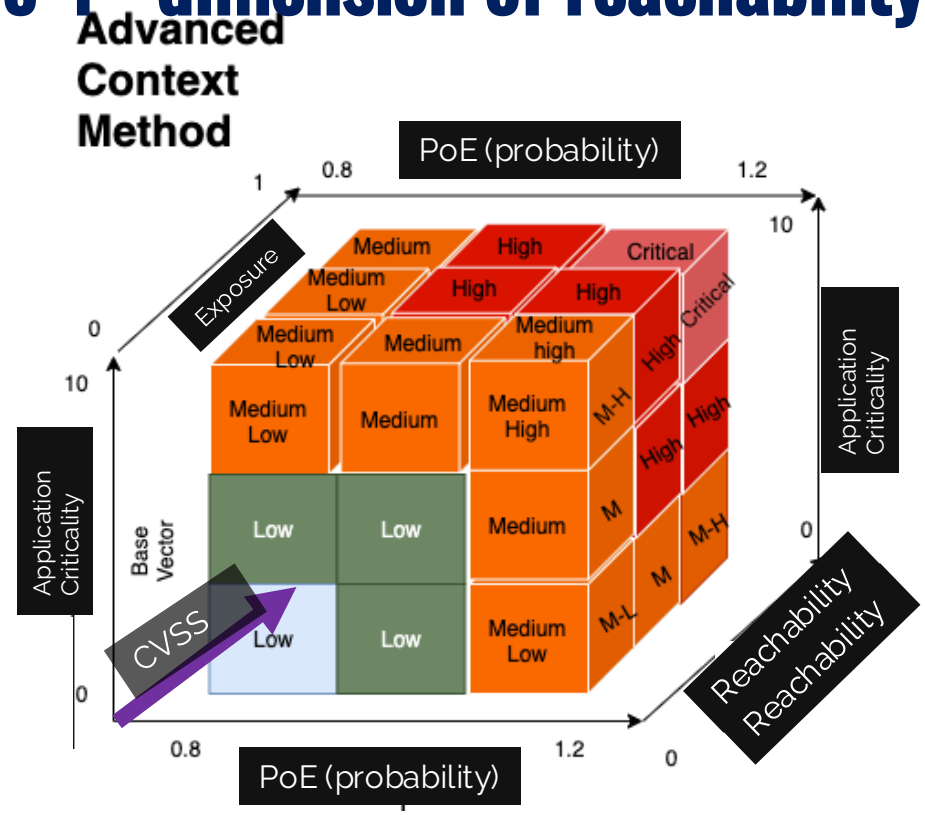
Phoenix brings out the 4th dimension of reachability



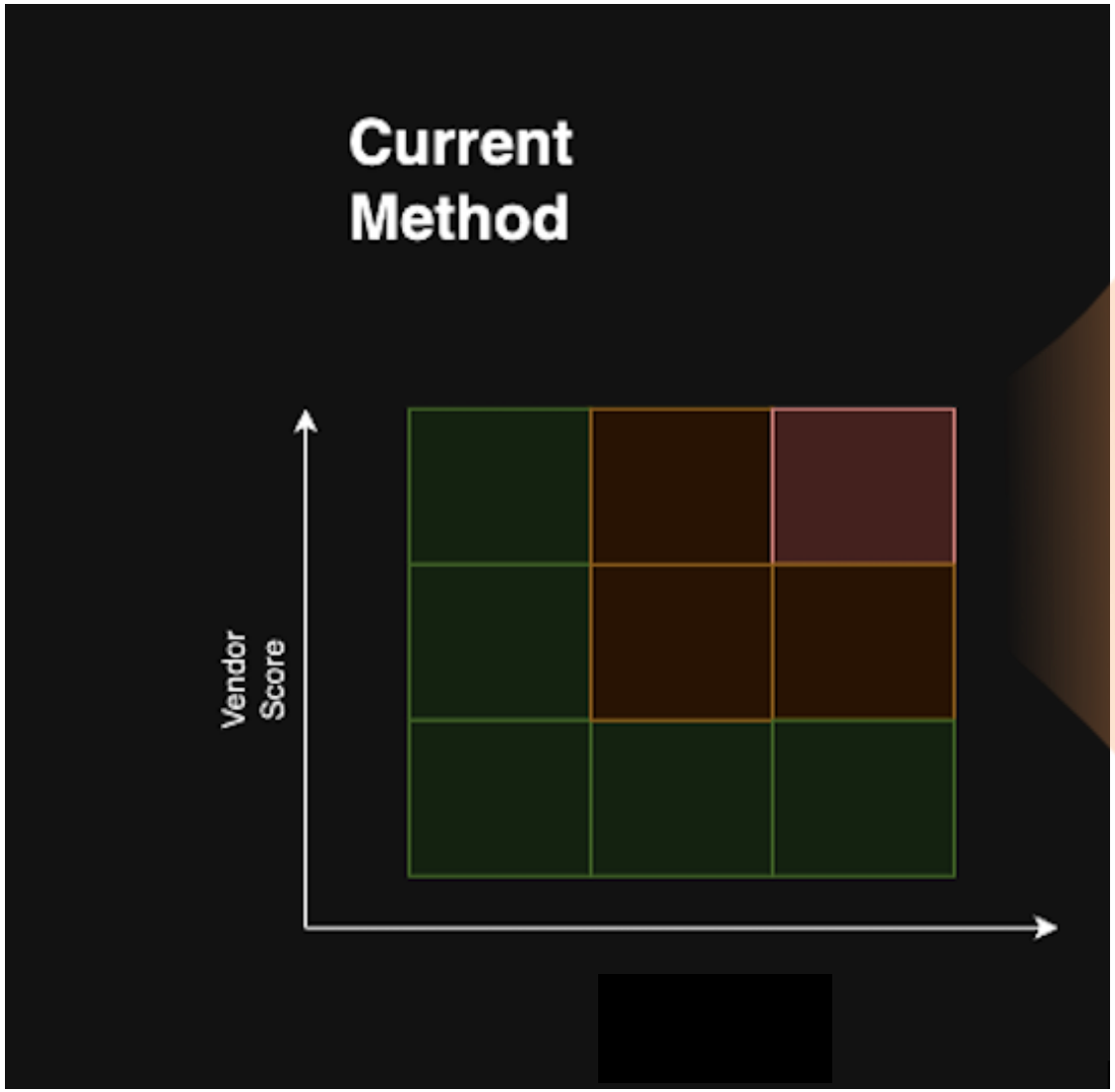
Vulnerability method from past

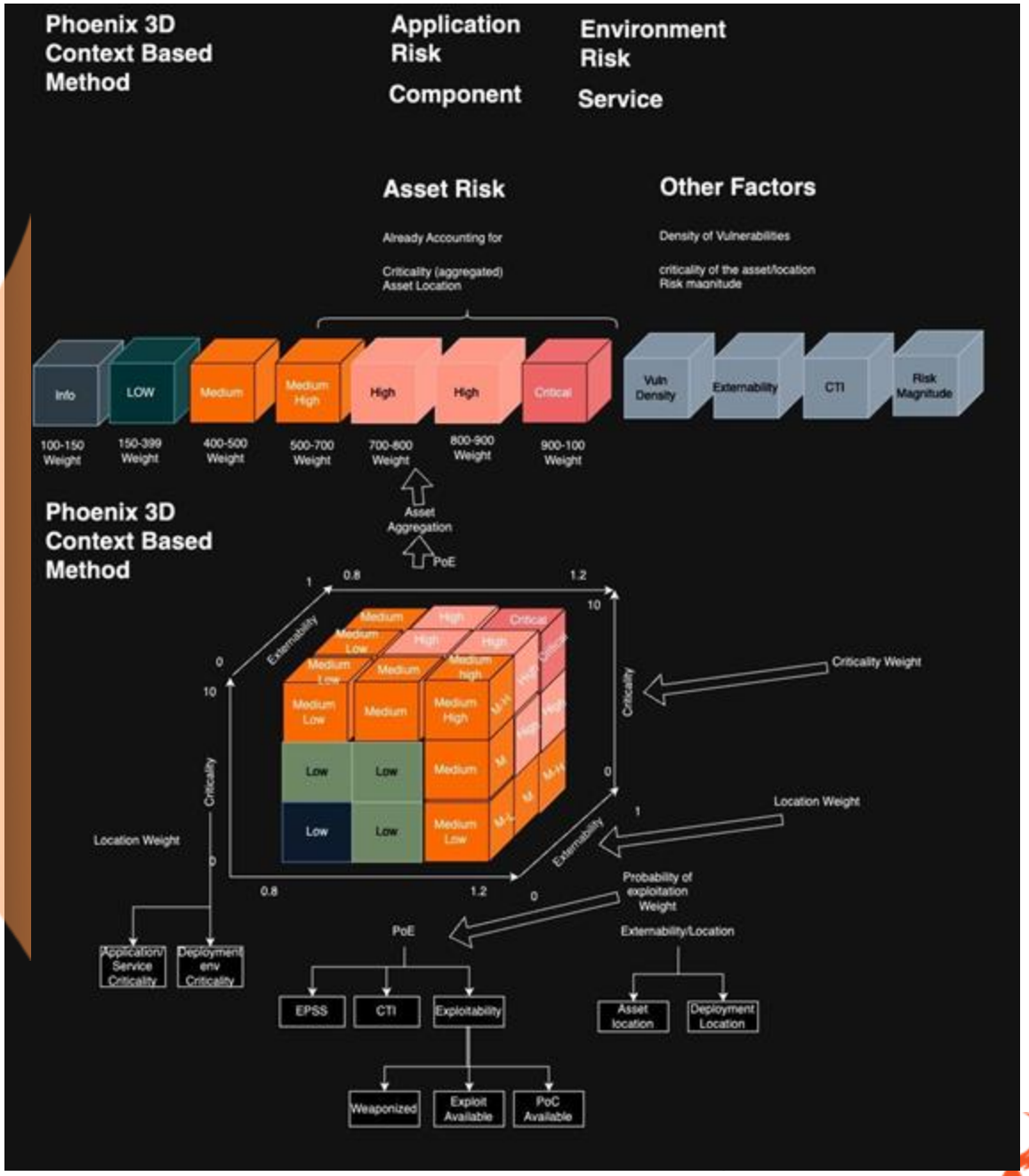
Phoenix 4D Contextual Reachability Risk

Phoenix brings out the 4th dimension of reachability

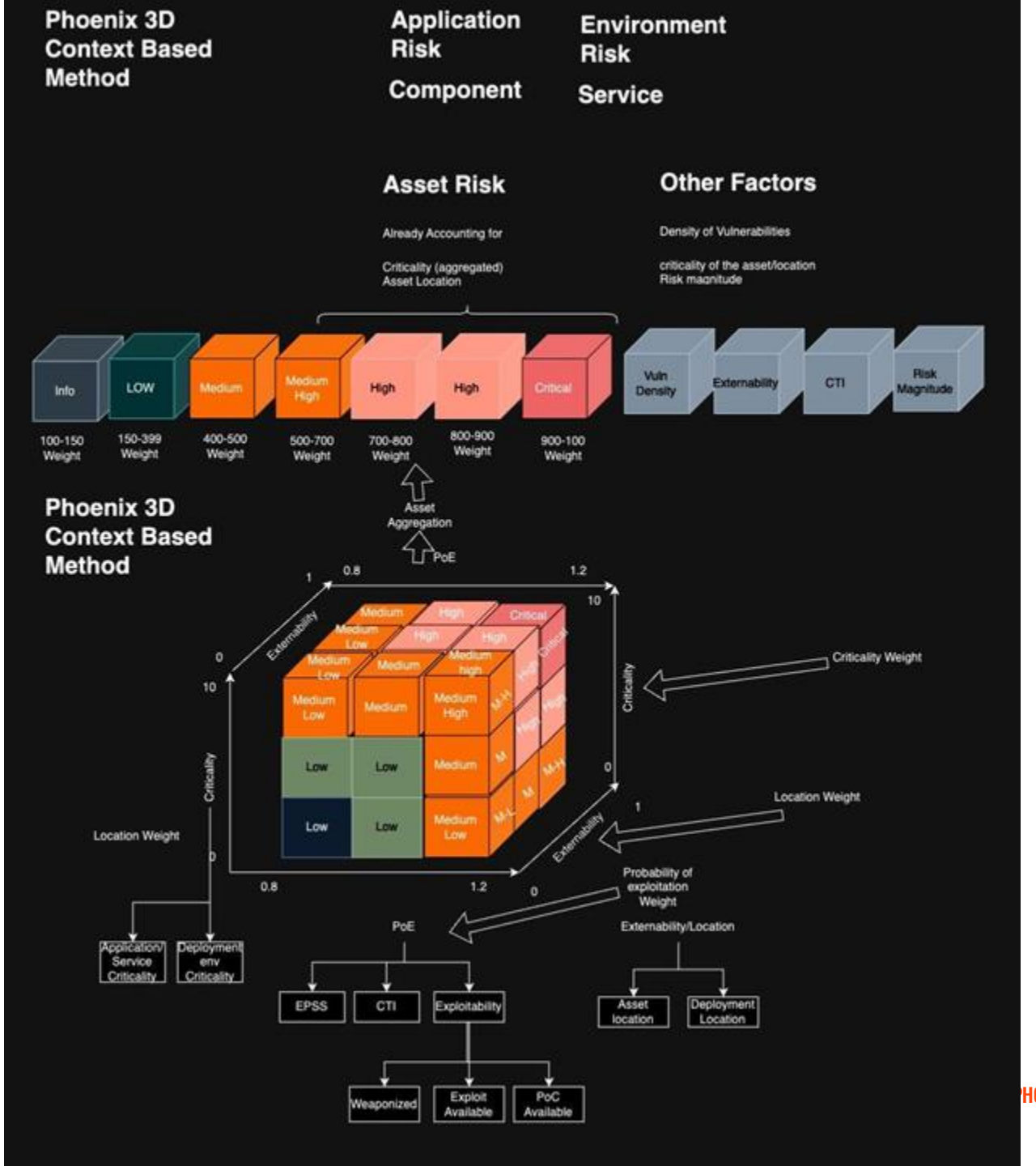


Evolution of Risk Method





Evolution


Phoenix 3D Context Based Method
Application Risk
Component
Environment Risk
Service
Asset Risk
Already Accounting for
Criticality (aggregated)
Asset Location
Other Factors
Density of Vulnerabilities
criticality of the asset/location
Risk magnitude
Info
LOW
Medium
Medium High
High
High
Critical
Vuln Density
Externability
CTI
Risk Magnitude
100-150 Weight
150-399 Weight
400-500 Weight
500-700 Weight
700-800 Weight
800-900 Weight
900-100 Weight
Asset Aggregation
PoE
Phoenix 3D Context Based Method
Externability
Criticality
Criticality Weight
Location Weight
Probability of exploitation Weight
Externability/Location
Application/ Service Criticality
Deployment env Criticality
EPSS
CTI
Exploitability
Asset location
Deployment Location
Weaponized
Exploit Available
PoC Available

Risk Augmentation / Prioritization

Business Units

Teams, Technology, Env Tags…

Organization

Environment Risk

Applications/ Env Assets

Applications

Services

Grp of Groups

Group of groups

Grp of assets

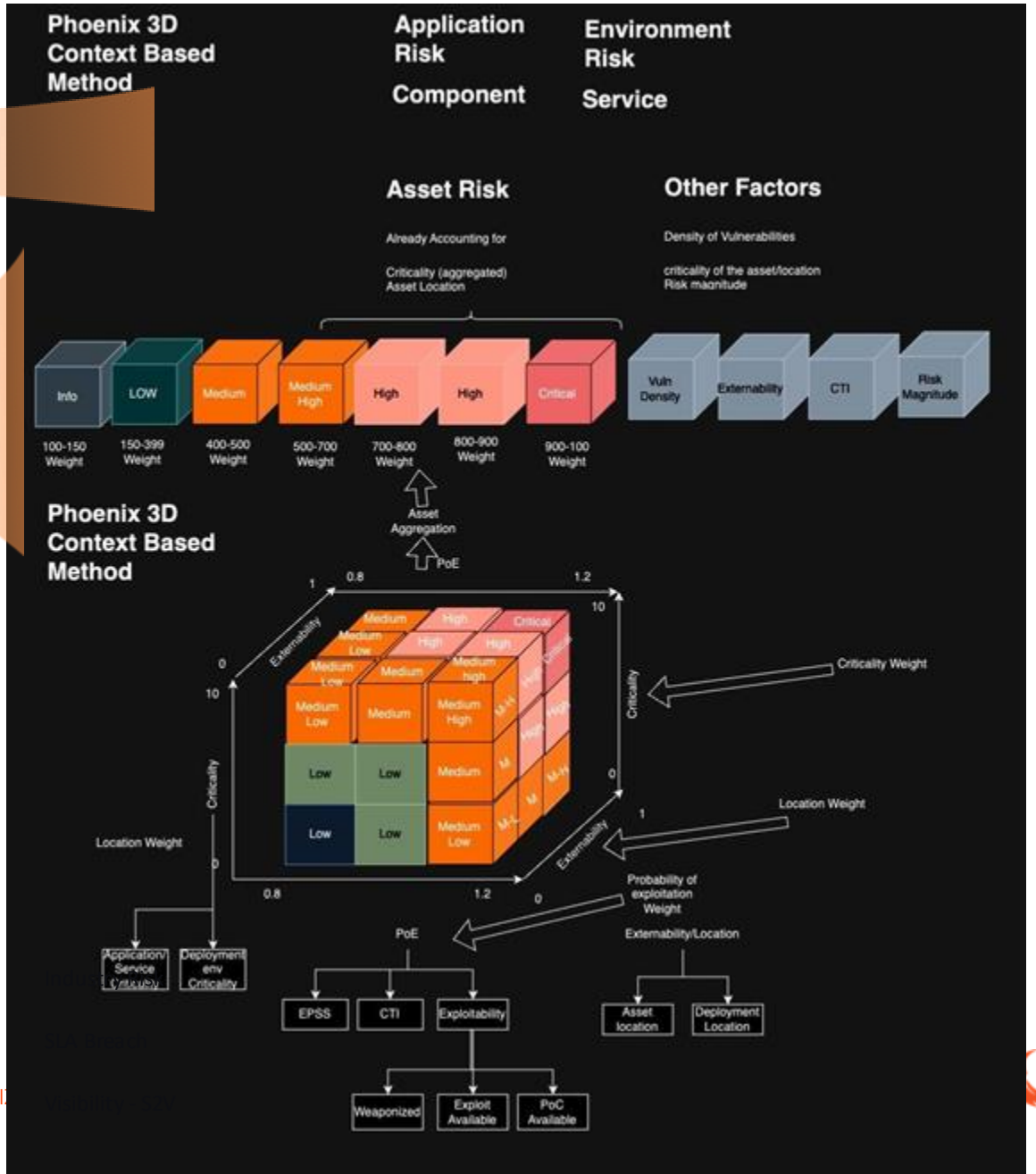
Grp of Env assets

Asset

Asset

Assets

Vuln

Vuln

Vulnerability